

One Banking AI

IA no setor financeiro · governança · soberania · engenharia

2026-07-08

EDIÇÃO Nº 25

COMO LER ESTE BRIEFING

Selos: **△ Impacto direto no negócio** = movimento de cliente/concorrente/regulador que afeta a operação agora. **Primeira mão** = item captado direto na fonte BR, fora das newsletters globais. Internacional entra como contexto — salvo marco global incontornável. *Uso interno e confidencial* — cruza com o estudo Where To Play Banking · One Banking (MTP 27-29).

⚡ A LEITURA DE HOJE

O banco brasileiro está construindo o parque de agentes mais rápido do que o mandato para governá-lo. O Itaú mostrou, na Semana de Produtos, uma cadeia de agentes que faz em **14 horas** o que levava **18 dias** (caso simulado de Pix por voz, do research ao refinamento), e o Bradesco opera a **~20 agentes por humano** sob a plataforma **Bridge**. No mesmo dia, o item de governança veio de fora e é incontornável: o **Rogue Agent**, falha crítica no **Google Dialogflow CX** (motor de chatbots muito usado em bancos), permitia que **uma única permissão de edição** (`dialogflow.playbooks.update`) **comprometesse todos os agentes do mesmo projeto** — lendo conversas ao vivo, exfiltrando PII/pagamentos e injetando mensagens — **sem deixar rastro no Cloud Logging**.

O QUE EU DIRIA NUM BOARD

Os dois fatos rimam, e é isso que importa. A métrica que a diretoria comemora — "1,3 mil modelos, 20 agentes por pessoa, ciclo 300% mais rápido" — é a mesma que mede **superfície de ataque e parque a governar**. Agente não é feature: é **identidade com credencial e permissão**, e o Rogue Agent prova que a granularidade da permissão define o raio do incidente — uma permissão mal escopada e o comprometimento não é de um bot, é do **projeto inteiro**, silencioso. A pergunta que separa quem governa de quem só escala não é "quantos agentes você tem", é **"cada agente tem mandato explícito — escopo, limite, credencial própria, trilha auditável — e você prova isso num incidente?"**. É o **Cohort** virando requisito operacional; e o **Veltrix** do outro lado — um parque que ninguém mede em custo é um parque que ninguém mede em risco. Contraponto: o Rogue Agent foi corrigido sem exploração conhecida e o Dialogflow não é a stack de todos — mas a lição de arquitetura (permissão granular, log imutável, credencial isolada) vale para qualquer motor, inclusive o interno que o Itaú constrói em ritmo de fábrica.

PRA USAR AMANHÃ

Rodar um **"censo do agent estate"**: uma linha por agente em produção (interno e cliente) — o que pode fazer, com que credencial/permissão, em que projeto compartilha ambiente, e se as alterações ficam logadas de forma imutável. É o inventário que transforma "temos muitos agentes" (slide de inovação) em "sabemos governar nossos agentes" (defesa no comitê de risco).

AGENTES & FORÇA DE TRABALHO

Itaú fabrica software com cadeias de agentes: ciclo de produto de 18 dias para 14 horas

△ **Impacto direto no negócio** · **Primeira mão** · BR

Na **Semana de Produtos 2026**, o Itaú detalhou como agentes de IA já participam do design e do desenvolvimento de software. Num experimento, uma **cadeia de agentes interconectados** simulou uma solução de **Pix por voz** (research, ideação, prototipação, teste de usabilidade, validação e refinamento) — processo que levaria **~18 dias** e foi concluído em **~14 horas**; em Seguros, squads relataram ganhos de **~300%** de velocidade. Contexto: **84%+** das iniciativas usam IA, **760+** com GenAI, **~56 mil** funcionários usam GenAI/dia e o banco declara **1,3 mil+ modelos de IA em uso**. (Let's Money; TI Inside; Mobile Time; IT Forum, 2026)

O QUE EU DIRIA NUM BOARD

Este item sustenta a leitura de hoje. O ganho é real e o Itaú está à frente — mas **"14 horas"** e **"1,3 mil modelos"** são, ao mesmo tempo, métrica de produtividade e de exposição. Uma cadeia que faz research→código sem humano no meio precisa de mandato tão explícito quanto um trader. O número que eu pediria não é a velocidade, é **quantos desses 1,3 mil modelos têm dono, mandato e trilha** — o denominador de governança do agent estate (Cohort).

PRA USAR AMANHÃ

Pegar o próprio one-pager de "fábrica de agentes" e adicionar a coluna que não aparece no slide: **quem é o dono, qual o mandato e onde está o log** de cada agente da cadeia.

Bradesco opera a ~20 agentes por humano com a plataforma Bridge

BR

O **Bradesco** consolida um modelo *AI-powered* em que times misturam pessoas e agentes na razão de **~20 agentes por humano**, orquestrados pela **Bridge** — plataforma proprietária que centraliza curadoria de modelos, publicação de serviços de IA e os **guard-rails** que definem o que cada agente pode fazer. A **BIA** registra **87% de resolutividade** e **25 mi de interações**. (Forbes; TI Inside; Convergência Digital, 2026)

O QUE EU DIRIA NUM BOARD

O Bradesco acertou a ordem — construiu a **camada de governança (Bridge)** junto com a proliferação, não depois. É o oposto do risco do Rogue Agent: guard-rail centralizado e curadoria de modelo são o "mandato por agente" que impede um bot de comprometer o resto. A pergunta de benchmark não é "quantos agentes por humano", é **"temos uma Bridge — um plano de controle único onde o mandato de cada agente**

é definido e auditado?". Sem plano de controle, 20 agentes por humano é sprawl; com ele, é escala governada.

PRA USAR AMANHÃ

Usar a Bridge como arquitetura-alvo: todo agente novo nasce registrado num plano de controle com mandato e log — nunca solto num projeto compartilhado.

GOVERNANÇA & RISCO

Rogue Agent: uma permissão no Google Dialogflow CX sequestrava todos os chatbots de um banco

⚠ **Impacto direto no negócio** · global · incontornável

A Varonis revelou o **Rogue Agent**: falha crítica no **Google Cloud Dialogflow CX** (motor de chatbots muito usado em serviços financeiros) que, via *Code Blocks*, permitia injetar código malicioso persistente na pipeline dos agentes. Com **uma única permissão de edição** (`dialogflow.playbooks.update`) sobre um agente, o atacante **comprometia todos os agentes do mesmo projeto GCP**, lia conversas ao vivo, exfiltrava dados sensíveis (PII, pagamentos) e fazia o bot pedir a senha do cliente — e as **alterações não eram registradas no Cloud Logging**. Reportada em nov/2025, corrigida pelo Google em jun/2026; **sem exploração conhecida**. (The Hacker News; Varonis; DarkReading; GBHackers, 07/07/2026)

O QUE EU DIRIA NUM BOARD

O detalhe que vale o incidente é "**sem log**". Um comprometimento silencioso num motor de chatbot bancário não é vazamento pontual — é **exfiltração contínua de conversa sensível** sem trilha para investigar. E o vetor é banal: **permissão mal escopada** em ambiente compartilhado. A lição atravessa qualquer fornecedor: **permissão granular por agente, credencial isolada e log imutável** são controles de primeira ordem. É due diligence de terceiro do **NIST AI RMF (GOVERN)** aplicada ao motor de agente — e a pergunta do CISO é "se um agente nosso for comprometido, o raio é de um bot ou do projeto todo?".

PRA USAR AMANHÃ

Auditar permissões dos motores de agente/chatbot (próprios e de fornecedor): quem tem `edit` sobre agentes, se agentes sensíveis dividem projeto com agentes de baixa criticidade, e se toda alteração gera log imutável.

Pix vira o principal alvo e a IA agêntica entra como arma do crime

BR

Levantamentos do dia reforçam que a **engenharia social sobre o Pix** é hoje o principal vetor de fraude digital no Brasil, e que a **IA agêntica** eleva a barra: diferente do bot que executa tarefa rígida, o agente malicioso **traça caminhos alternativos para contornar barreiras**. Para **83%** dos executivos ouvidos, separar atividade legítima assistida por IA de ação maliciosa é **extremamente difícil**. (Let's Money/BioCatch; Portal Information Management, 07/07/2026; WeLiveSecurity, 2026)

O QUE EU DIRIA NUM BOARD

O dado incômodo é o **83%**. Se a maioria dos executivos não distingue IA legítima de maliciosa no próprio tráfego, a defesa por regra fixa acabou — o crime tem agente adaptativo, e só detecção comportamental adaptativa responde. Isso move o CAPEX de fraude de "mais regras" para "mais sinal e contexto por transação". Conecta com o MED 2.0 (Nº 24): a instituição corre contra o relógio de contestação e contra um atacante que aprende.

PRA USAR AMANHÃ

Transformar o "83% não distingue" em pergunta de comitê — *quais dos nossos controles de fraude ainda são regra fixa e quais já são adaptativos?* — priorizando os canais novos (voz, WhatsApp, agente).

SOBERANIA

Vazamento de chaves Pix no Agibank: cada nova integração é um novo ponto de exfiltração

⚠ **Impacto direto no negócio** · BR

O **Banco Central** divulgou incidente de segurança com dados de clientes do **Agibank**, com exposição de **mais de 5 mil chaves Pix**. O episódio se soma à série recente de incidentes e reacende a discussão sobre **residência e proteção de dados** em cadeias cada vez mais distribuídas de agentes e integrações. (Seu Dinheiro/Banco Central, 2026)

O QUE EU DIRIA NUM BOARD

Soberania de dados não começa na jurisdição da nuvem — começa no **inventário de quem toca o dado**. Cada agente novo, cada integração de Open Finance, cada conector é um ponto adicional de exfiltração; a mesma proliferação que acelera o Itaú multiplica os pontos onde uma chave Pix pode vazar. Rogue Agent e Agibank contam a mesma história por ângulos diferentes: **o risco migrou da borda para a malha de agentes e integrações**. Governança de dado, aqui, é roteamento por sensibilidade — princípio do **Veltrix**.

PRA USAR AMANHÃ

Mapear, para os dados mais sensíveis (chave Pix, credencial, dado de crédito), **por quais agentes e integrações eles transitam** — e onde falta isolamento.

IA EM SERVIÇOS FINANCEIROS

Nubank: o modelo de crédito por IA expande a carteira +40%, mas o custo de crédito sobe +72%

BR

O **Nubank** credita à IA a expansão da **receita líquida de juros** e o avanço "controlado" para segmentos de maior risco. A carteira total cresceu **+40% a/a**, a **US\$ 37,2 bi**, puxada por cartão e crédito pessoal (Brasil e México). Mas o **custo de crédito subiu +72% a/a**, com aumento de provisões e pressão sobre a qualidade percebida da carteira; a ação recuou após o resultado. Vélez: *"não estamos adicionando IA ao sistema financeiro; estamos reconstruindo o sistema financeiro em torno da IA"*. (Bloomberg Línea, 2026)

O QUE EU DIRIA NUM BOARD

Melhor caso de **FinOps de crédito** do trimestre. Quando a IA vira motor de originação e empurra a carteira para maior risco, o **ganho aparece primeiro** (margem de juros) e o **custo aparece depois** (provisão, com defasagem). Ler só "+40% de carteira" ou "IA reconstruindo o banco" é fé; a régua é **Δ carteira vs. Δ custo de crédito** — e aqui o custo cresceu ~1,8x mais rápido que a carteira. Não é veredito contra a IA de crédito (pode ser sazonal), mas lembra que **modelo de crédito por IA é sistema de alto risco** (PL 2338 / EU AI Act) e que o board precisa exigir o custo no denominador antes de comemorar o ganho.

PRA USAR AMANHÃ

Institucionalizar o indicador " **Δ carteira vs. Δ custo de crédito**" como leitura obrigatória de todo case de IA em originação — o número que separa expansão saudável de risco represado.

ECONOMIA DE IA & FINOPS

Bancos BR investiram R\$ 47 bi em tech em 2025 — R\$ 4,7 bi só em segurança e fraude

dado / BR

Segundo a **Febraban**, as instituições financeiras investiram **R\$ 47 bi em tecnologia em 2025**, dos quais **R\$ 4,7 bi** exclusivamente em **segurança e prevenção à fraude**. Entre executivos, **88%** creem que compartilhar inteligência entre bancos reduziria fraude e **89%** defendem acesso em tempo real à conta destinatária. (Febraban, 2026)

O QUE EU DIRIA NUM BOARD

O **R\$ 4,7 bi** é o piso do problema, não o teto. Com a proliferação de agentes (Itaú, Bradesco) e canais (Pix por voz, WhatsApp), o custo de defender e o de inferir crescem **na mesma curva** — e nenhum tem, hoje, denominador por agente/caso de uso. É o vão que o **Veltrix** cobre: sem observabilidade por agente, "investimos R\$ 4,7 bi em segurança de IA" é orçamento, não FinOps. O número que falta no slide é **custo por agente governado**.

PRA USAR AMANHÃ

Pedir a decomposição do orçamento de IA/segurança **por agente e por caso de uso** — se não existe, é o primeiro diagnóstico de FinOps a entregar.

REGULATÓRIO BRASIL

Banco Central planeja usar IA em novo *score* de risco de fraude do Pix

regulatório / BR

O **Bacen** estuda incorporar **IA a um novo *score* de risco de fraude** nas transações Pix, na esteira das medidas antifraude (IN BCB 664/2025 e o MED 2.0). O regulador passa, ele próprio, a operar modelo de IA sobre o trilho de pagamento. (Finsiders Brasil, 2026)

O QUE EU DIRIA NUM BOARD

Quando o **regulador vira operador de IA** sobre o Pix, o jogo antifraude ganha um terceiro modelo no meio — o do BC. Para a instituição, é oportunidade e exposição: alinhar sinal com o *score* do regulador reduz atrito, mas divergência entre o modelo interno e o do BC vira ponto de auditoria. Sinal antecipado de **governança imposta de cima** — o regulador definindo o baseline de detecção.

PRA USAR AMANHÃ

Mapear onde o modelo interno de fraude vai **conversar (ou divergir)** do futuro *score* do BC — antes de a régua chegar pronta.

PL 2338 segue na Câmara com a ANPD posicionada como coordenadora do SIA

regulatório / BR

O **PL 2338/2023** (marco legal da IA), aprovado no Senado em dez/2024, segue em tramitação na Câmara para votação em 2026. Mantém o modelo à europeia (classificação por risco), cria o **SIA** e posiciona a **ANPD** como reguladora residual e **coordenadora do SIA** (PLP de dez/2025); prevê **sanção de até R\$ 50 mi**. O **EU AI Act** entra em vigor em **ago/2026**. (Convergência Digital; JOTA; ANPD/gov.br, 2026)

O QUE EU DIRIA NUM BOARD

Direção clara mesmo sem data — recomendação de investimento e **crédito por agente** (vide Nubank) cai em **alto risco**: transparência, explicação, contestação. Quem desenhar governança agora com o **EU AI Act como proxy** atravessa sem retrabalho; quem esperar refaz a stack sob prazo. Que a **ANPD** seja o hub reforça o elo IA↔dados pessoais — governança de agente e de dado são o mesmo problema.

PRA USAR AMANHÃ

Classificar hoje, pelo rascunho do PL, quais casos de IA da casa serão "alto risco" — e começar por eles a trilha de explicabilidade e contestação.

NO RADAR

- **Rogue AI em chatbots corporativos (The Neuron, 08/07)** · a edição do dia lidera com "um agente rogue pode sequestrar chatbots corporativos" e traz a nova **lei de IA de Illinois** e modelos chineses mais baratos. *Confirma o tema do dia: segurança de agente virou pauta de capa.*
- **Sam Boboev (08/07)** · reports sobre **banking com blockchain/stablecoin e depósito tokenizado em bancos canadenses**. *Watch de soberania monetária — tema já destilado na N° 24; acompanhar o Canadá como precedente.*
- **FGC / caso Master** · liquidações de Master, Will Bank e Banco Pleno já custaram **R\$ 51,8 bi** ao FGC; operações da PF em bancos digitais (Digimais). *Risco de crédito e de balanço no ecossistema de fintechs — pano de fundo do caso Nubank.*
- **Febraban Tech 2026 · 24–26/ago** · tema "Agentes Inteligentes, Liderança Humana". *Marco BR para publicar tese de governança de agentes.*

Rogue Agent (Dialogflow CX)	1 permissão comprometia todos os agentes do projeto; sem log (Varonis/THN)
Itaú · fábrica de agentes	ciclo 18 dias → 14h; 1,3 mil+ modelos; ~56 mil usam GenAI/dia (Let's Money)
Bradesco · agent estate	~20 agentes/humano; BIA 87% resolutividade, 25 mi interações (Forbes)
Nubank · crédito por IA	carteira +40% a/a (US\$ 37,2 bi); custo de crédito +72% a/a (Bloomberg Línea)
Tech/segurança (BR, 2025)	R\$ 47 bi em tech; R\$ 4,7 bi só em segurança/fraude (Febraban)

NUBANK: CRESCIMENTO DA CARTEIRA VS. CUSTO DE CRÉDITO (A/A)



O custo de crédito cresceu ~1,8x mais rápido que a carteira: o ganho da IA na originação aparece **antes** de o custo aparecer na provisão. É o núcleo do FinOps de crédito — exigir o custo no denominador antes de comemorar a expansão. Fonte: Bloomberg Línea (resultados Nu Holdings, 2026).

APRENDIZADO DO DIA

Agent estate é o conjunto de todos os agentes de IA que uma organização opera (internos e voltados ao cliente). **Agent sprawl** é sua proliferação sem inventário nem mandato — o "shadow IT" da era dos agentes. O **Rogue Agent** mostra por que o inventário importa: quando agentes compartilham projeto/credencial, comprometer **um** pode comprometer **todos**. Governar o *estate* é responder, por agente: **quantos existem, o que cada um pode fazer (mandato), com que credencial, em que ambiente e com que trilha auditável**. Sem isso, "temos muitos agentes" é slide de inovação; com isso, é controle — e é a tese do **Cohort**.

Fontes do dia: Let's Money, TI Inside, Mobile Time, IT Forum (Itaú); Forbes, Convergência Digital (Bradesco/Bridge); The Hacker News, Varonis, DarkReading, GBHackers (Rogue Agent/Dialogflow CX); Let's Money/BioCatch, Portal Information Management, WeLiveSecurity (fraude Pix/IA agêntica); Seu Dinheiro, Banco Central (Agibank); Bloomberg Línea (Nubank); Febraban (tech/segurança); Finsiders Brasil (score de fraude do BC; FGC/Master); Convergência Digital, JOTA, ANPD/gov.br (PL 2338/SIA); The Neuron (rogue AI/Illinois); Sam Boboev.